

CYBER CONTROL READINESS: Internal Audit Case Study

Evidence sufficiency, control validation, and remediation traceability in a fictional DoD contractor support environment

Field	Details
Prepared by	Mallory Davis
Fictional organization	Arclight Mission Systems
Report date	May 2026
Document type	Portfolio work sample
Audit type	Targeted cyber control readiness internal audit
Reference basis	NIST SP 800-37 Rev. 2, NIST SP 800-53 Rev. 5, NIST SP 800-53A Rev. 5, NIST SP 800-171 Rev. 3

CONCLUSION	Arclight has selected control practices in place. The audit identifies readiness risk where evidence packages, population coverage, and remediation closure records do not support repeatable review. Four findings require management action before external assurance pressure increases.
------------	---

USE NOTE	This fictional case study demonstrates audit scoping, control assessment, evidence sufficiency judgment, finding development, POA&M planning, and executive risk communication. It is not a certification assessment, penetration test, or full RMF authorization package.
----------	--

Section Tabs and Reader Guide

Use the tabs below to move to the part of the case study most relevant to your review. Each section stands alone, but the full report is designed to read as one audit path from scope to management decision.

1. Case Brief	2. Risk Register	3. Control Matrix	4. Evidence Review
5. Findings	6. POA&M	7. Executive Summary	

Section	What it demonstrates
Case Study Brief	Scope, triggers, methods, and limitations
Risk Register	Priority risks and rating rationale

Control-to-Evidence Matrix	Selected controls, evidence requests, and assessment methods
Evidence Sufficiency Review	What was received and what remains unproven
Formal Findings	Condition, implication, and corrective action logic
POA&M	Owners, timing, milestones, and closure proof
Executive Summary	Decision-ready conclusion for leadership

1. Case Study Brief

[Back to section tabs](#)

Arclight Mission Systems is a fictional mid-sized defense and GovTech contractor. The audited environment supports staff who coordinate contractor-facing program delivery, controlled project work, and internal technology services.

The audit evaluates whether selected cyber control practices are sufficiently designed, evidenced, and tracked to support contractor readiness, leadership decision-making, and future external review preparation.

Audit triggers

- Readiness planning for future contractor assurance expectations.
- A delayed offboarding case that exposed weak HR-to-access reconciliation traceability.
- Leadership uncertainty about whether privileged access review evidence covers the full in-scope population.
- Fragmented remediation tracking across separate records with no single view of aging high-severity items.

Scope

Area	Included	Excluded
Access governance	MFA, privileged access review, joiner/mover/leaver traceability, periodic review evidence	IAM architecture redesign or tool replacement
Evidence readiness	Traceability, sufficiency criteria, population coverage proof	Formal CMMC certification or third-party assessment
Remediation tracking	Vulnerability aging, escalation thresholds, POA&M linkage, closure	Penetration testing or threat simulation
Supporting records	Logging review cadence, tabletop follow-through, emergency change approvals	Full SOC operating model or SIEM architecture assessment

Methods and assessment basis

Method	Application in this case study
Examine	Policies, access review packets, HR records, tickets, exports, tabletop records, tracker fields
Interview	Control owners for access, vulnerability remediation, incident response, and change management
Test	Sample traceability checks and tie-outs between source records and closure records

Audit criterion	How it is applied
Evidence sufficiency	Source, population, reviewer, decision, exceptions, and closure are defined or recoverable from the record.
Access closure	Audit criteria use same-business-day privileged access removal and 24-hour standard account removal unless documented exception exists.
Remediation aging	Audit criteria use internal thresholds of Critical 15 days, High 30 days, Moderate 90 days unless exception approval exists.
Emergency change evidence	Retroactive approval record is expected for emergency changes before closure of the ticket.

LIMITATIONS	This case study evaluates selected readiness risks. It does not issue a certification result, authorize a system, or claim full coverage of every control family.
--------------------	---

2. Risk Register

[Back to section tabs](#)

The register frames six risks where control practice, evidence quality, or remediation traceability could weaken Arclight's ability to support clear risk decisions. Ratings are qualitative and scoped to this fictional internal audit. Note on differentiated ratings: R-01 and R-02 carry the same overall High rating but for distinct reasons, R-01 is High because residual access after separation is an immediate, ongoing exposure; R-02 is High because incomplete population coverage means the review itself cannot be relied upon, regardless of whether it found issues. These are different risk profiles warranting different remediation sequencing.

ID	Risk theme	Rating	Risk statement	Response	Finding
R-01	Offboarding traceability	High	Delayed separation or role-change closure can leave residual access active.	Mitigate	F-01
R-02	Privileged access validation	High	Review evidence does not prove full population coverage or exception disposition.	Mitigate	F-02
R-03	Remediation aging	Moderate/High	Aged high-severity vulnerabilities are split across tools without a single escalation view.	Mitigate	F-03
R-04	Logging review evidence	Moderate	Records show review activity but do not consistently support reperformance.	Mitigate	F-04
R-05	Incident response follow-through	Moderate	Tabletop lessons are not consistently converted into tracked corrective actions.	Mitigate	F-04
R-06	Emergency change approvals	Moderate	Approval records for selected emergency changes do not consistently close the audit trail.	Mitigate	F-04

Rating rationale

R-01: A delayed access removal control creates ongoing exposure after an employee separates or changes role. The immediate concern is not ticket quality. It is whether access remains active after the business trigger exists.

R-02: A privileged access review only provides assurance if the review population is defined and complete. Without a population source, leadership cannot rely on the conclusion.

R-03: Remediation records that sit across separate tools can hide aging items. A vulnerability program cannot govern what leadership cannot see in one reviewable view.

R-04: Evidence that a log review occurred is weaker than evidence showing what was reviewed, what was found, and how exceptions were handled.

R-05: A tabletop exercise loses value when lessons learned do not become owned, tracked corrective actions.

R-06: Emergency changes bypass normal routing. Retroactive approval and documented rationale are the traceability controls that keep urgency from becoming ungoverned change.

3. Control-to-Evidence Matrix

[Back to section tabs](#)

The matrix shows how selected control expectations were translated into evidence requests, status judgments, and assessment methods. It is selective by design. It demonstrates assessment execution, not a full control catalog.

Control	Focus	Evidence requested	Status	Risk	Method
AC-2	Account management	HR separations and role changes; ITSM tickets; SSO status export	Partial	R-01	Examine, Interview
AC-6	Least privilege	Privileged inventory; role justification; review signoff; population source	Partial	R-02	Examine, Test
IA-2(1)	Privileged MFA	MFA policy; MFA export; exception log	Available, incomplete tie-out	R-02	Examine, Test
SI-2	Flaw remediation	Scan summary; ticket aging by severity; exception approvals; escalation records	Partial	R-03	Examine, Interview
AU-2	Event logging	Logging standard; source list; retention configuration extract	Available	R-04	Examine, Test
AU-6	Audit record review	Monthly review record; reviewer; events reviewed; exceptions; disposition	Partial	R-04	Examine, Interview
IR-3	Incident response testing	Tabletop agenda; attendance; after-action report; corrective action assignments	Available, closure gap	R-05	Examine, Interview
CM-3	Change control	Change ticket trail; emergency change approval record	Partial	R-06	Examine, Test
CA-5	POA&M	Tracker with finding IDs, owners, dates, closure artifacts, overdue item report	Partial	R-03 / R-05	Examine

4. Evidence Sufficiency Review

[Back to section tabs](#)

The evidence review tests whether the available record supports the control claim within scope. A control activity may exist and still fail the sufficiency review if the record cannot support repeatable assessment.

Sufficiency standard

Criterion	Meaning
Source	The evidence identifies the system, file, report, or authoritative record used.
Population	The evidence shows the full in-scope population or the sample basis used.
Reviewer	The evidence identifies who reviewed or approved the activity.
Decision	The record shows the decision, result, or control outcome.
Exceptions	Exceptions are identified with rationale and disposition.
Closure	The record shows the issue was resolved or accepted through defined authority.

Evidence review results

ID	Evidence item	Assessment	What the record shows	Required follow-up
E-01	HR separations and role changes	Partial	HR triggers exist. Closed-loop reconciliation to ITSM ticket closure and SSO status is incomplete.	Reconcile each event to closure status and retain monthly exception evidence.
E-02	Privileged account inventory and MFA export	Population gap	Control fragments exist, but the privileged review population is not defined clearly enough to validate completeness.	Define authoritative population source and retain one complete certification package.
E-03	Quarterly access review packet	Partial	Review signoffs exist. Exception resolution is not consistent across owners.	Standardize exception outcomes and approver evidence in the review template.
E-04	Vulnerability scan and ticket aging export	Partial	Open items are visible, but aging and escalation cannot be reperformed from one consolidated view.	Create consolidated aging view and retain monthly escalation record.
E-05	Logging source list and retention review	Available	Source coverage and retention configuration are documented.	Add review checklist evidence to monthly AU-6 review process.
E-06	Incident tabletop package	Available, closure gap	Exercise occurrence is documented. Corrective actions are not tracked to closure.	Convert lessons learned into POA&M entries with owners and closure proof.
E-07	Sample change tickets	Partial	Standard changes show approvals. Emergency change records are inconsistent.	Document retroactive emergency approval criteria and test compliance.
E-08	Risk and remediation tracker	Partial	The tracker lists items but does not always contain closure criteria or closure evidence.	Add closure criteria and closure evidence fields before any item can be closed.

Review summary	Assessment
Strongest evidence	E-05 logging source list and E-06 tabletop package establish that underlying activities occurred.
Most material gap	E-02 privileged access review evidence does not prove complete population coverage.
Most important follow-up	Tie access reviews and remediation items to closure criteria and reviewable closure evidence.

5. Formal Findings

[Back to section tabs](#)

Each finding links an expected practice to an observed condition, explains the risk, and defines management action. The findings are intentionally bounded. They focus on evidence gaps and governance gaps rather than dramatized control failure.

F-01 - Offboarding access closure is not consistently traceable to completion

Field	Details
Related risk	R-01
Controls	AC-2, PS-4, PS-5
Severity	High

Expected practice: Arclight audit criteria require privileged access removal within the same business day and standard account removal within 24 hours of a confirmed separation or role-change trigger. Completion must reconcile HR record, ITSM closure, and current access status.

Observed condition: In the 90-day sample, 7 of 23 separation records did not have a closed ITSM ticket traceable to completed access removal within the stated timeframe. Current SSO status could not be confirmed for 4 of the 7 cases from the records provided.

Risk implication: Leadership cannot determine whether access removal is operating as designed. The gap increases residual access risk and weakens contractor assurance readiness.

Recommendation: Implement a monthly HR-to-access reconciliation and escalate any late closure without documented exception approval.

F-02 - Privileged access review evidence does not prove complete population coverage

Field	Details
Related risk	R-02
Controls	AC-2, AC-6, IA-2(1)
Severity	High

Expected practice: For this audit, a sufficient privileged access review package includes the population source, accounts reviewed, reviewer identity, review date, exception log, and exception disposition.

Observed condition: Privileged account reports, MFA exports, and review signoffs were provided. The evidence package does not identify the authoritative source used to define the privileged account population.

Risk implication: The review may be complete, but the audit cannot validate that it is complete. This weakens least privilege assurance and would invite follow-up in an external contractor review.

Recommendation: Build a quarterly privileged access certification package tied to an authoritative population source and retain one completed review cycle as closure evidence.

F-03 - Vulnerability Remediation Aging Lacks a Consolidated Escalation View

Field	Details
Related risk	R-03
Controls	SI-2, CA-5, RA-5
Severity	Moderate-High

Expected practice: Arclight audit criteria use internal escalation thresholds of 15 days for Critical, 30 days for High, and 90 days for Moderate vulnerabilities unless exception approval is documented.

Observed condition: Three High-severity items exceeded the 30-day threshold. One item remained open for 47 days with no documented escalation or exception approval. Split records prevented efficient confirmation of the full aged-item population.

Risk implication: Leadership lacks a single decision-ready view of remediation status. Aged items can remain unresolved without clear escalation.

Recommendation: Create a consolidated remediation aging dashboard with written escalation rules and monthly leadership review evidence.

F-04 - Operational evidence confirms activity occurred but does not consistently show risk closure

Field	Details
Related risk	R-04, R-05, R-06
Controls	AU-6, IR-3, CM-3, CA-5
Severity	Moderate

Expected practice: For this audit, operational evidence must show the activity performed and the disposition of issues it produced. Log reviews need a reviewer and exception disposition. Tabletop lessons need assigned corrective actions. Emergency changes need retroactive approval records.

Observed condition: Across three areas, records confirm activity occurred but do not consistently close the control loop: AU-6 review records lack stable disposition evidence, IR tabletop lessons are not converted into owned actions, and 2 of 4 sampled emergency changes lacked retroactive approval records.

Risk implication: Controls can appear active while their outputs are not governed to closure. This weakens assurance quality and increases follow-up work during review.

Recommendation: Add closure proof criteria to log review, tabletop follow-up, and emergency change records, then track the revised evidence through the POA&M.

6. POA&M and Remediation Plan

[Back to section tabs](#)

Each POA&M item is designed to close a documented finding with ownership, timing, milestones, closure proof, and an escalation path. The plan shows how findings become auditable remediation work.

POA&M	Finding	Owner	Due	Corrective action	Closure evidence
P-01	F-01	IT Security + HR Operations	30 days	Build automated monthly reconciliation of HR separations and role changes to ITSM closure and current access status. Flag accounts beyond timing criteria and document exceptions.	Reconciliation report, exception log, and signed review record.
P-02	F-02	IAM Lead	45 days	Create a privileged access certification package with authoritative population source, reviewer, account outcomes, exceptions, and sign-off. Complete one full review cycle.	Completed certification package for one full review cycle.

P-03	F-03	Vulnerability Manager	45 days	Create a consolidated aging dashboard combining scan findings, ticket status, days open, severity, and escalation status. Establish monthly leadership review.	Dashboard export, escalation SOP, and first leadership review record.
P-04	F-04	GRC Manager	60 days	Update log review, incident tabletop, and emergency change templates so each record shows disposition, owner, and closure evidence.	Updated templates plus one sample record from each process showing closure proof.

P-01 milestone and escalation detail

Milestones: Week 1: define data sources. Week 2: build reconciliation template. Week 3: run first review and resolve exceptions. Week 4: manager sign-off.

Escalation Trigger: Any account remaining active more than 24 hours beyond HR-confirmed separation (standard) or same business day (privileged) without documented exception approval triggers automatic escalation to IT Security Manager and HR Director. Unresolved within 48 hours escalates to CISO.

Closure Evidence Required: (1) Monthly reconciliation report showing HR records reconciled to ITSM and SSO status; (2) Exception log showing any late closures with rationale and approver; (3) Sign-off from IT Security Manager confirming review. All three required before P-01 is marked closed.

P-02 milestone and escalation detail

Milestones: Week 1: define population source and template. Weeks 2-3: complete full review. Weeks 4-5: resolve exceptions. Week 6: audit closure review.

Escalation Trigger: Any privileged account that cannot be attributed to an authorized role or business justification within 5 business days of the review cycle is escalated to the CISO with a recommendation for immediate suspension. Any exception to MFA enforcement requires written CISO approval with documented risk acceptance.

Closure Evidence Required: Completed certification package for one full quarterly cycle containing all six required elements: population source, account list, reviewer, date, outcomes, exception log. Package must be reviewed and accepted by the audit lead before P-02 is marked closed.

P-03 milestone and escalation detail

Milestones: Week 1: define aging logic. Weeks 2-3: build dashboard and SOP. Weeks 4-5: conduct first leadership review. Week 6: audit closure review.

Escalation Trigger: Critical or High items exceeding internal timing criteria without exception approval must appear in the leadership view.

Closure Evidence Required: (1) Dashboard export showing current aging status across all open items; (2) Written escalation SOP excerpt defining thresholds and process; (3) Record of first monthly leadership review with sign-off. All three required before P-03 is marked closed.

P-04 milestone and escalation detail

Milestones: Week 1: draft revised templates. Weeks 2-3: approve with process owners. Weeks 4-6: collect sample evidence. Week 8: audit closure review.

Escalation Trigger: Incomplete review records are returned for correction; missing tabletop actions or emergency approval records are logged as unresolved evidence exceptions.

Closure Evidence Required: (1) Updated AU-6 review checklist template with required fields; (2) Sample POA&M entries from the next tabletop exercise corrective actions; (3) Updated CM policy excerpt covering emergency change approval; (4) Sample closed emergency change ticket showing retroactive approval. All four required before P-04 is marked closed.

7. Executive Risk Summary

[Back to section tabs](#)

Overall conclusion: Arclight maintains key cybersecurity control practices, but supporting evidence does not yet consistently demonstrate completeness, traceability, or remediation closure. This creates moderate readiness risk and weakens management reliance during future review activity.

Priority	Leadership question	Answer	Decision requested
1	Can Arclight substantiate that privileged access reviews cover the complete in-scope population?	Not yet	Approve P-02 and require one complete certification package tied to an authoritative population source.
2	Can Arclight prove that offboarding triggers translate to completed access removal with reviewable evidence?	Not yet	Approve P-01 and require monthly reconciliation evidence.
3	Can leadership see aged remediation items and escalation decisions without assembling records across tools?	Not yet	Approve P-03 and require one consolidated aging view with review evidence.

Management decisions requested

Decision	Why now	Expected result
Approve P-01 through P-04 owners and due dates	The findings are bound and ready for corrective action.	Accountable closure path for all four findings.
Require sufficiency fields in evidence packages	Current records show activity, but not always source, population, exception, and closure logic.	Reduced reconstruction risk in future reviews.
Escalate aged remediation into one leadership view	Split records obscure timing and exception decisions.	Faster risk decisions and clearer residual risk visibility.